

SIH26106 · MAILTRACE

How the prototype works

A screenshot-backed explanation of the parser, score, origin view, campaign graph, PDF evidence, and optional Groq/Qwen analyst assist.

The one-line idea

Drop a saved email. Get an explainable case file.



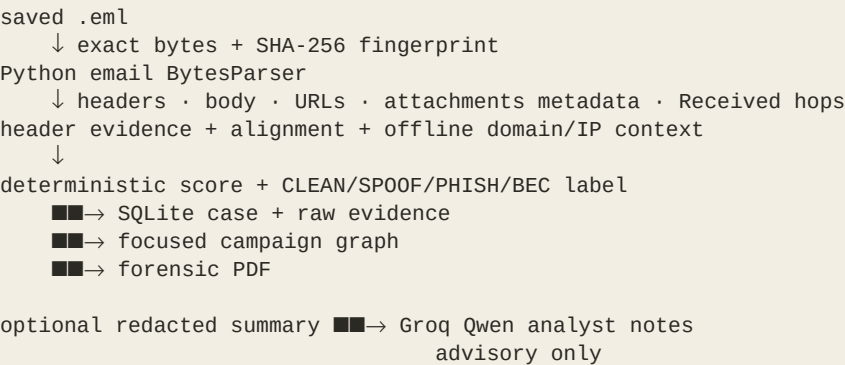
Figure 1 — the real localhost landing screen: eight crafted samples plus raw .eml upload.

Scope in one sentence

MailTrace is a local-first analyst lab. It accepts a saved RFC 5322 email, preserves its fingerprint, extracts forensic signals, produces a deterministic risk indicator, stores evidence locally, correlates campaign candidates, and exports a report. It is not Gmail ingest, not a live authentication verifier, and not a human-location or attacker-attribution system.

1. The 30-second mental model

Think of MailTrace as a controlled evidence pipeline, not a black-box spam button.



The separation that matters

- The parser and deterministic rule fusion decide the displayed score, label, reasons, authentication state, and graph rules.
- Qwen sees a minimal redacted evidence summary only. It can add observations and recommended actions, but it cannot change the score or label.
- The UI and PDF repeat uncertainty boundaries so a demo claim does not quietly become a production claim.

Runtime components

Layer	What is actually running
Browser UI	Vanilla HTML/CSS/JavaScript dossier served by FastAPI.
API	FastAPI routes on 127.0.0.1:8777.
Parsing	Python email.policy + BytesParser for MIME/RFC 5322 content.
Evidence	SQLite case store plus SHA-256-named raw .eml files.
Correlation	NetworkX graph converted to a small API response and custom SVG.
Origin view	Received-header heuristic plus a deliberately small offline demo table.
Reports	ReportLab PDF generated from the stored case.
Optional analyst	Groq OpenAI-compatible endpoint using qwen/qwen3.8-27b.

2. What happens when an email is uploaded

Step 1 — the API accepts bytes

The UI sends the selected file to POST /api/analyze. Demo buttons use POST /api/analyze-sample/{name}. Empty uploads and unknown sample names are rejected. The server does not connect to Gmail or Outlook.

Step 2 — the original bytes get a fingerprint

The exact upload bytes are hashed with SHA-256. That hash becomes the evidence storage key and is shown in the case so an analyst can tell which file produced the report.

Step 3 — structured fields are extracted

- From display name, address and domain; Reply-To; Return-Path; Subject; Date; Message-ID.
- Authentication-Results, Received-SPF and ARC authentication evidence.
- Plain-text body, limited locally to 4,000 characters; URLs deduplicated to 20.
- Received headers, candidate public IPs, a probable earliest public hop and cached infrastructure context.
- Attachment filename, MIME type, byte size and SHA-256 metadata, limited to 20. Attachments are never executed.

MAILTRACE SIH26106 · analyst lab
localhost · no Gmail ingest

Drop a saved email. Get a case file.
 .eml upload or a demo sample. Origin = hosting city, not a person.

Upload .eml
 Choose File No file chosen

01_clean.eml 02_display_spoof.eml 03_lookalike.eml 04_spf_fail.eml 05_bec_invoice.eml 06_cred_phish.eml
 07_cloud_hops.eml 08_campaign_twin.eml

SPOOF · 04_spf_fail.eml
 id 8074f27c · SPF: fail DKIM: fail DMARC: fail 64
SPOOF

CLAIMS TO BE Exam Cell <notice@pec.edu.in> RETURN-PATH <notice@pec.edu.in>	REPLY-TO — MESSAGE-ID <spf-004@rogue.example>
---	--

HEADER ALIGNMENT FROM / REPLY-TO unknown OVERALL unknown	FROM / RETURN-PATH aligned
---	--------------------------------------

REASONS

1. SPF fail. This server is not allowed to send as the claimed domain.
2. DKIM fail. Signature does not match.
3. DMARC fail.
4. First public hop is AWS, Frankfurt — cloud, not campus mail.

RECEIVED CHAIN

- from rogue.example (rogue.example [18.184.10.20]) by mx.example.net with ESMTP id d4; Sun, 30 Aug 2026 14:00:00 +0000
 18.184.10.20 · Frankfurt · AWS · known

ORIGIN MAP

SIGNALS (WITH SOURCE)

+22 [spf_fail] SPF fail. This server is not allowed to send as the claimed domain. (source: message-header)

+12 [dkim_fail] DKIM fail. Signature does not match. (source: message-header)

Figure 2 — the live 04_spf_fail case: score, sender fields, alignment, reasons, Received chain and origin map.

3. Headers, authentication evidence, and origin

Authentication is evidence read from the file

MailTrace scans the authentication headers already present in the .eml. Each of SPF, DKIM and DMARC becomes pass, fail, unknown, or conflict. The API marks the source as message-header, verification_mode as header-stated, and verified as false. A contradictory pass/fail observation becomes conflict and never silently resolves to pass.

Visible field	What the prototype means
SPF / DKIM / DMARC	Header-stated values, not a new DNS or cryptographic check.
From / Reply-To	Domain comparison for alignment and mismatch signals.
From / Return-Path	Domain comparison for delivery-identity alignment.
Received chain	Parsed hop lines with candidate IP, status and cached context.
Origin	Last public Received entry in parsed header order; confidence is heuristic.

Origin means infrastructure, not a person

Private addresses such as 10.x, 127.x and 192.168.x are skipped when looking for a public hop. The selected hop is looked up in a small offline table used for the crafted samples. A Frankfurt/AWS result describes hosting context behind the observed hop; it does not locate a human, prove ownership, or attribute an attack.

Offline intelligence

The demo domain cache supplies fields such as age, registrar and status from a checked-in JSON table. There is no live WHOIS, DNS, blacklist, threat-intelligence feed, or maintained global GeoIP database in this prototype.

4. How the deterministic score is calculated

The score is intentionally inspectable

Every case starts at 8. Matching signals add fixed points, the total is clamped to 0–100, and up to six strongest reasons are shown. The score is an explainable risk indicator, not a probability, accuracy percentage, or trained classifier.

Signal	Points	Source / meaning
Visible Gmail address wearing an official title	+28	message-header
Reply-To domain mismatch	+18	message-header
Return-Path domain mismatch	+10	message-header
SPF fail	+22	message-header
DKIM fail	+12	message-header
DMARC fail	+12	message-header
Lookalike domain	+20	body / URL heuristic
Young cached domain	+14	offline-cache
Cloud-origin first public hop	+10	Received + offline-cache
Password or login request	+16	body heuristic
Invoice / payment redirect language	+18	body heuristic
Urgency language	+8	body heuristic

Label order matters

- PHISH first: score ≥ 70 plus a password/login or lookalike reason.
- BEC next: score ≥ 50 plus payment, BEC or invoice language.
- SPOOF next: score ≥ 55 plus title, SPF or Reply-To evidence; otherwise score ≥ 45 .
- Otherwise CLEAN. A clean case with no reasons receives an alignment/no-cue explanation.

Why this is defensible in a demo

An analyst can add the visible points and see why the label happened. The method is transparent and reproducible, while the UI explicitly avoids pretending that a fixed rule sum is a calibrated probability.

5. Worked example: 04_spf_fail.eml

The displayed 64 is not magic

base score	8
SPF fail	+22
DKIM fail	+12
DMARC fail	+12
cloud-origin hop: AWS, Frankfurt	+10
	■■■■■
deterministic total	64

The case is labeled SPOOF because the score is above the spoof threshold and the reasons contain SPF evidence. The From and Return-Path domains are aligned in this fixture, while Reply-To is absent; the complete authentication failure still drives the result.

- The Received line supplies 18.184.10.20 as the probable public hop.
- The offline table renders that hop as Frankfurt / AWS / known.
- The UI shows the map as a visual origin aid, not as an attacker map.
- The Qwen panel adds observations and actions separately; it does not recalculate 64.

3. DMARC fail.

4. First public hop is AWS, Frankfurt — cloud, not campus mail.

SIGNALS (WITH SOURCE)

+22 [spf_fail] SPF fail. This server is not allowed to send as the claimed domain. (source: message-header)

+12 [dkim_fail] DKIM fail. Signature does not match. (source: message-header)

+12 [dmarc_fail] DMARC fail. (source: message-header)

+10 [cloud_origin] First public hop is AWS, Frankfurt — cloud, not campus mail. (source: Received header + offline-cache)

QWEN ANALYST ASSIST (ADVISORY)

available · groq · qwen/qwen3.8-27b

spoofing

OBSERVATIONS

• SPF,

• The e

• The b

• No UR

RECOMMENDED ACTIONS

• Quar

• Bloc

• Aler

• Veri

The email exhibits strong indicators of spoofing due to complete authentication failure (SPF, DKIM, DMARC) and a mismatch between the claimed domain (pec.edu.in) and the actual origin (AWS Frankfurt). The deterministic label 'SPOOF' is consistent with these findings. While no malicious link or attachment is explicitly present in the evidence, the reference to a link in the body warrants caution. This should be treated as a spoofing attempt until proven otherwise.

Advisory Qwen output; not a validated classifier and not the deterministic score.

OFFLINE DOMAIN CACHE

pec.edu.in: 4000d [known]

Download case PDF

Raw .eml evidence

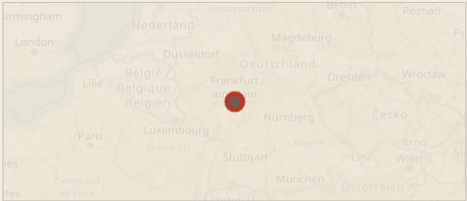
URLS

URL: none extracted.

ATTACHMENTS (METADATA ONLY, NEVER EXECUTED)

Attachments: none; metadata-only handling, never executed.

ORIGIN MAP



Offline origin list (deterministic):

• 18.184.10.20 · Frankfurt · AWS · known

CAMPAIGN GRAPH

SHARED INDICATORS, NOT IDENTITY PROOF

04

spf fail

analysed email

Figure 3 — the same live case lower down: signals, Qwen advisory panel, offline cache, PDF/evidence actions and provenance.

Source-grounded walkthrough · demo evidence only

6

6. What the three SIH bots and Qwen do

The three Bot Mode profiles now share one Groq route

Profile	Provider	Model	Tools
sih-grok46	groq	qwen/qwen3.8-27b	file + terminal
sih-luna56	groq	qwen/qwen3.8-27b	file + terminal
sih-minimaxm3	groq	qwen/qwen3.8-27b	file + terminal

The provider is optional, not the detector

The app sends Qwen a minimal redacted evidence summary. It includes bounded subject/body text, domains, alignment, header-stated authentication, masked IPs, safe URLs without query strings, attachment metadata without bytes, selected hop context, and the deterministic result for explanation. It does not send raw .eml bytes, attachment bytes, query strings, or unmasked email addresses.

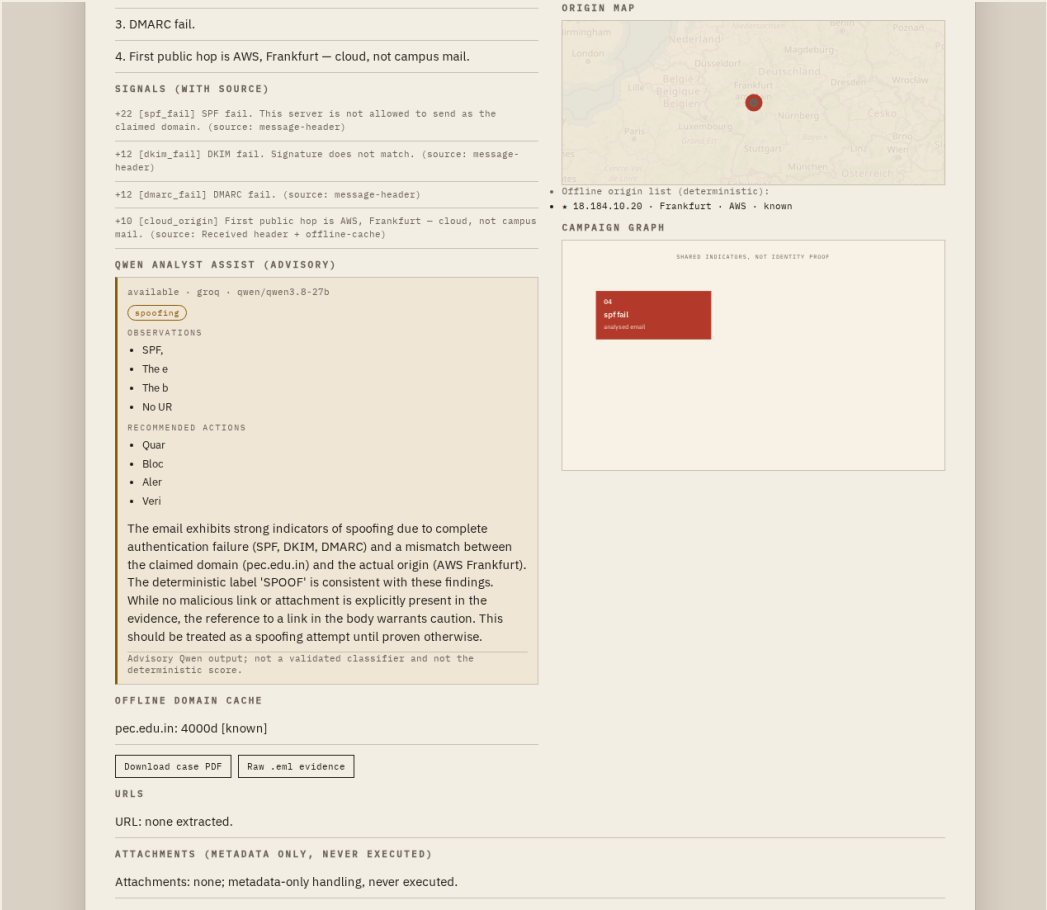
Qwen is constrained to return JSON with threat types, observations, recommended actions, an analyst note, and a manual-review flag. Invalid or unavailable provider responses fall back to a truthful unavailable status while the deterministic case remains complete.

Hard boundary

Qwen cannot override score, label, evidence, authentication conflict handling, origin rules, graph edges, or the safety disclaimers. validated is always false. It must not claim attacker identity, human location, live authentication, probability, or confidence.

Why the profiles use a small tool set

Groq's free-tier request budget is limited. The full Hermes tool catalog made the Bot Mode prompt too large and triggered HTTP 413. The three authorized profiles therefore use only file and terminal tools for a normal Qwen run, keeping the local analyst workflow under the provider limit.



7. How campaign correlation works

The graph is a candidate relationship view

Each filename contributes one current node. The graph compares meaningful parsed indicators: Reply-To address, non-generic domains, and observed public hop IPs. A shared Reply-To is meaningful by itself; otherwise at least two non-IP indicators are required. IP-only relationships are rejected.

MAILTRACE SIH26106 · analyst lab
localhost · no Gmail ingest

Drop a saved email. Get a case file.
 .eml upload or a demo sample. Origin = hosting city, not a person.

Upload .eml
 Choose File No file chosen

01_clean.eml 02_display_spoof.eml 03_lookalike.eml 04_spf_fail.eml 05_bec_invoice.eml 06_cred_phish.eml
 07_cloud_hops.eml 08_campaign_twin.eml

SPOOF · 08_campaign_twin.eml
 id 73e9f019 · SPF: fail DKIM: none DMARC: fail 66
SPOOF

CLAIMS TO BE Campaign Desk <followup@mail-secure.net>	REPLY-TO camp@mail-secure.net
RETURN-PATH <camp@mail-secure.net>	MESSAGE-ID <cloud-000@mail-secure.net>

HEADER ALIGNMENT

FROM / REPLY-TO aligned	FROM / RETURN-PATH aligned
OVERALL aligned	

REASONS

1. SPF fail. This server is not allowed to send as the claimed domain.
2. DMARC fail.
3. Young domain in offline cache: mail-secure.net
4. First public hop is AWS, Frankfurt — cloud, not campus mail.

SIGNALS (WITH SOURCE)

- +22 [spf_fail] SPF fail. This server is not allowed to send as the claimed domain. (source: message-header)
- +12 [dmarc_fail] DMARC fail. (source: message-header)
- +14 [young_domain] Young domain in offline cache: mail-secure.net (source: offline-cache)
- +10 [cloud_origin] First public hop is AWS, Frankfurt — cloud, not campus mail. (source: Received header + offline-cache)

QWEN ANALYST ASSIST (ADVISORY)

available · groq · qwen/qwen3.8-27b

spoofing

OBSERVATIONS

- SPFA
- DMARC
- The d
- The f
- The e

RECOMMENDED ACTIONS

RECEIVED CHAIN

- from mx.google.com (mx.google.com [8.8.8.8]) by mailbox.pec.edu.in with ESMTLS id h8a 8.8.8.8 · unknown · public-dns · known
- from ec2-18-184.eu-central-1.compute.amazonaws.com (ec2-18-184.eu-central-1.compute.amazonaws.com [18.184.10.20]) by mx.google.com with ESMTLS id h8b 18.184.10.20 · Frankfurt · AWS · known

ORIGIN MAP

Offline origin list (deterministic):

- 8.8.8.8 · unknown · public-dns · known
- 18.184.10.20 · Frankfurt · AWS · known

CAMPAIGN GRAPH

SHARED INDICATORS, NOT IDENTITY PROOF

```

graph LR
    07[07 cloud hops  
analyzed email] --- 08[08 campaign twin  
received email]
  
```

Figure 5 — the real 07 → 08 campaign demo: two case nodes and one relationship caption.

Live graph readback: 2 nodes / 1 edge

Shared API indicators: dom:mail-secure.net, ip:18.184.10.20, rt:camp@mail-secure.net

Rendered caption: domain: mail-secure.net + same hop: 18.184.10.20 + Reply-To: camp@mail-secure.net

The API itself labels the relation campaign-candidate and states that shared indicators do not prove common control, identity, or responsibility. This is correlation for analyst attention, not attribution.

8. Evidence storage, masking, and the PDF report

What is persisted locally

Artifact	Purpose
data/mailtrace.db	Case ID, filename, SHA-256, parsed JSON payload and creation time.
data/evidence/<sha256>.eml	Original raw bytes, checked again against the parsed SHA-256 before serving.
data/reports/	Generated case PDFs.
/api/case/{id}/masked	Masked case view for safer sharing.
/api/case/{id}/evidence	Raw message/rfc822 evidence only when the stored hash still matches.
/api/case/{id}/pdf	ReportLab PDF generated from the stored case.

What the report is honest about

- SHA-256 is an integrity fingerprint, not a blockchain.
- The local custody events are a prototype trace, not legal-grade chain of custody.
- Retention is caller-configured; there is no default retention period in this prototype.
- Authentication values come from message headers; no independent live DNS or DKIM verification is performed.

MailTrace case file

```
id 73e3f019 SPOOF score 66
Evidence file: 08_campaign_twin.eml
Evidence hash: 88150d129f60c4e9f08a2d4d469abccdb7b12aa547ca1586799e74675
New evidence stored: yes
Evidence storage key: bf8848a150d1c219f60c4e9f08a2d4d469abccdb7b12aa547ca1586799e74675.eml
```

Sender and header evidence

Subject: Shared campaign B

Authentication evidence

```
SPF: fail
sig: none
DKIM: none
Return-Path:
Return-Path on source: message-header
Return-Path on source: id:
independent verification: no
raw authenticating headers: Authentication-Results: mx.google.com; spf=fail
raw authenticating headers: dkim=none dmarc=fail
```

URLs and attachments

Attachment: none, metadata-only handling, never executed

Detection and origin

```
Method: deterministic=rule-fusion
Model, status: not-configured
```

Qwen analyst assist

```
status: available  
provider: grog  
model: gwen/gwen3.8-27b  
validated: no  
types: spoofing
```

Recommended action: Qua

Analysis note: The email exhibits strong indicators of spoofing, including SPF and DMARC failures, a young domain, and a suspicious subject line. The presence of a link to a legitimate domain (e.g., <https://www.fox.com>) and the fact that malicious links or attachments were detected, but the authentication failures are sufficient to classify this as a **Spoofing threat**.

```
Signal+42 [Signal fail] SPF fail. This server is not allowed to send
Signal+43 [Signal fail] DMARC fail. (source: message-header)
Signal+44 [Signal fail] Young domain. Young domain in offline cache: ma
```

Signed: 10/10/2016 09:01 First public hop is AWS, Frankfurt - cloud, not campus mail. (source: Received
 header of offline cache)
 Hop 0: 8.8.8.8:80 observed public hop: 18.184.10.20, Frankfurt | AWS | cloud, identity
 Hop 1: 8.8.8.8:80 observed public hop: 18.184.10.20, Frankfurt | AWS | cloud, identity
 Hop 2: 8.8.8.8:80 unknown | HOSTING-ONS | from mx.google.com (mx.google.com [8.8.8.8]) by
 mx.google.com [8.8.8.8] with smtpd [8.8.8.8] and from ec2-18-184-us-central-1.compute.amazonaws.
 com [ec2-18-184-us-central-1.compute.amazonaws.com [18.184.10.20]] by mx.google.com with Es

Campaign candidate

Shared indicators form a campaign candidate; they do not prove common control, identity, or responsibility.

```
Relationship: dala7940 -- 73
Campemail-secure.net | stren
rt:campemail-secure.net
```

[illegible]

Figure 6 — the actual one-page PDF generated for the 08 campaign case.

9. How to run and demonstrate it

Start the reproducible local path

```
cd /root/sih-mailtrace
./run.sh

# run.sh loads the ignored .env, regenerates samples,
# runs the test suite, and starts Uvicorn on 127.0.0.1:8777
```

Open this URL in the VM browser

http://127.0.0.1:8777/

Recommended live demo order

- Click 04_spf_fail.eml. Point to 64, SPOOF, the three failed auth stamps, the reasons and Frankfurt/AWS hosting context.
- Scroll through the Qwen panel. Say “advisory” out loud; the rule score remains authoritative.
- Click Download case PDF and show the case fingerprint/provenance.
- For the graph, clear old local cases, then click 07_cloud_hops.eml followed by 08_campaign_twin.eml. The focused graph should be 2 nodes / 1 edge.
- For an upload demo, use a crafted .eml only. Do not upload real private mail while Qwen is enabled.

Clean graph command

```
curl -X POST http://127.0.0.1:8777/api/reset
```

Reset deletes the local demo cases and their stored evidence. Run it only when you want a clean campaign demonstration.

Useful API checks

Request	Expected purpose
GET /api/health	Product, PS ID and safe Qwen runtime status.
GET /api/samples	Eight demo filenames and byte sizes.
POST /api/analyze-sample/04_spf_fail.eml	Live deterministic case plus optional advisory.
POST /api/analyze	Raw multipart .eml upload.
GET /api/graph	All current deduplicated graph nodes/edges.

10. Mobile view and the honest boundary



Figure 7 — the same landing flow at 390px: buttons stack without horizontal overflow.

Implemented now

- Local saved-email upload and eight deterministic demo fixtures.
- MIME/header/body parsing, authentication evidence, alignment, URLs, attachment metadata and Received-hop analysis.
- Explainable score, label, reasons, provenance, SHA-256 evidence and local case retrieval.
- Offline domain/IP context, map view, focused campaign graph and PDF export.
- Optional redacted Groq/Qwen analyst notes with offline/unavailable fallback.

Partial, offline, or intentionally absent

- No validated NLP/ML detector or calibrated probability. The deterministic score is not a trained model.
- No live DNS, WHOIS, threat-intelligence, blacklist or independent SPF/DKIM/DMARC cryptographic verification.
- No person geolocation, attacker identity, human attribution or legal-grade custody.
- No Gmail/Outlook ingestion, malware execution, attachment detonation or public multi-user account system.

- The graph is local shared-indicator correlation, not full campaign attribution.

Public hosting is a separate hardening project

The current app is safe for the localhost SIH prototype boundary, but it is not ready to expose directly to the public internet: it has no auth layer, public reset/case routes, no rate limiting, no durable MailTrace service, and no MailTrace route in the existing Caddy config. A real hosted demo needs an access gate or allow-list, upload limits, protected reset, rate limits, loopback app binding behind TLS, persistent service management, backups, and a separate subdomain/VM.

11. What was verified for this walkthrough

Live checks

Check	Observed result
UI landing	HTTP 200; eight sample buttons and .eml file input rendered.
04 case	64 / SPOOF; reasons, map, evidence, PDF and Qwen advisory visible.
07 → 08 graph	2 nodes / 1 edge; caption derived from API shared indicators.
Raw upload	01_clean.eml → 8 / CLEAN; SHA-256 evidence stored; advisory available.
Mobile	390px viewport; scrollWidth equals clientWidth; no console errors.
API	Health 200; eight samples; case/evidence/masked/PDF routes respond.
Regression	38 tests passed; Python compilation, shell syntax and source diff checks passed.

Source map

File	Role
app.py	FastAPI routes and orchestration.
mailtrace/parse.py	MIME parsing, auth evidence, hops, origin, URLs and hashes.
mailtrace/score.py	Fixed points, label order and uncertainty text.
mailtrace/graph_store.py	Meaningful shared-indicator graph rules and captions.
mailtrace/store.py	SQLite persistence and hash-checked evidence storage.
mailtrace/llm_assist.py	Redaction, Groq request, strict JSON normalization and fallback.
mailtrace/pdf_report.py	Case PDF generation.
ui/index.html	Rendered dossier UI and API-derived graph caption.
tests/test_pipeline.py	Deterministic, graph, PDF, privacy and Qwen regression coverage.

Final status

The local SIH prototype is ready to demonstrate on a laptop/VM. The optional bots and Qwen route are live and advisory. The generated six-slide submission deck still needs the registered Team ID and Team Name inserted into its title slide before upload; hosting publicly is not required for the idea round.